

SLP-ISMS-009 v.1.0 Statement of Applicability Date 27 February 2026				
Control	Name	Applicable	Justification / source	Status
5.1	Policies for information security	Yes	ISMS foundation; supersedes 2019 directive (E11)	Impl
5.2	Roles and responsibilities	Yes	Previously undefined (E02); SLP-ISMS-004	Impl
5.3	Segregation of duties	Yes	Invoice approval chain; admin vs user accounts	IP
5.4	Management responsibilities	Yes	MD commitment per Policy §4	Impl
5.5	Contact with authorities	Yes	GDPR notification duty (ÚOOÚ); 2025 incident unreported (E12)	IP
5.6	Contact with special interest groups	Yes	CSIRT.SK advisories via MSP	PI
5.7	Threat intelligence	Yes	Applicable — SMEs in Slovakia are actively targeted by ransomware and phishing c	PI
5.8	InfoSec in project management	Yes	Applies to e-shop development projects	PI
5.9	Inventory of assets	Yes	SLP-ISMS-006; domain ownership gap RSK-019	Impl
5.10	Acceptable use	Yes	Dropbox shadow IT (E06); AUP SLP-POL-001	IP
5.11	Return of assets	Yes	No offboarding checklist (E04); RSK-017	IP
5.12	Classification of information	Yes	Recipes/pricing = confidential (E02, E06)	IP
5.13	Labelling	Yes	Follows 5.12; document templates	PI
5.14	Information transfer	Yes	Dropbox misuse RSK-013; BEC RSK-012	IP
5.15	Access control	Yes	P SLP-POL-002	IP
5.16	Identity management	Yes	Applicable — unique identity management required across all users and systems; c	IP
5.17	Authentication information	Yes	Passwords on monitor (E05); new P SLP-POL-003	IP
5.18	Access rights	Yes	Never reviewed (E03); RSK-004, RSK-007, RSK-017	IP
5.19	Supplier relationships security	Yes	5 critical suppliers; P SLP-POL-006	IP
5.20	Supplier agreements	Yes	NetAdmin/WebFront contract gaps (E09, E10)	PI
5.21	ICT supply chain	Yes	Applicable — key providers (HostPoint, NetAdmin) may rely on their own sub-contra	PI
5.22	Supplier service monitoring	Yes	VPS/VPN dependencies RSK-006, RSK-015	PI
5.23	Cloud services security	Yes	M365, PayWell, MSP cloud backup	IP
5.24	Incident mgmt planning	Yes	2025 incident mishandled (E12); P SLP-POL-005 + CIRP	IP
5.25	Assessment of events	Yes	Triage per Incident Policy	IP
5.26	Response to incidents	Yes	CIRP procedures	IP
5.27	Learning from incidents	Yes	2025: no lessons learned (E12) — now mandatory step	IP
5.28	Collection of evidence	Yes	2025: logs never examined (E12); RSK-016	PI

5.29	Security during disruption	Yes	Warehouse outage precedent RSK-006	PI
5.30	ICT readiness for BC	Yes	VPN fallback, e-shop continuity RSK-015	PI
5.31	Legal/contractual requirements	Yes	GDPR, customer contracts; RSK-020	IP
5.32	Intellectual property	Yes	Recipes = core IP (E02); ownership of e-shop source code to be clarified in WebFro	PI
5.33	Protection of records	Yes	Accounting/HR retention duties	PI
5.34	Privacy and PII	Yes	GDPR; records of processing missing (E04) RSK-020	IP
5.35	Independent review	Yes	External support for impartial audits (SLP-ISMS-010)	PI
5.36	Compliance with policies	Yes	Internal audit programme	IP
5.37	Documented procedures	Yes	IT knowledge "in my head" (E03) RSK-011	PI
6.1	Screening	Yes	Standard HR checks for finance/IT roles	PI
6.2	Terms of employment	Yes	NDA in contracts (E04) — extend with security duties	IP
6.3	Awareness and training	Yes	None existed (E04); phishing precedent RSK-001	IP
6.4	Disciplinary process	Yes	Policy §5 + Labour Code	Impl
6.5	Post-employment duties	Yes	RSK-004, RSK-017	IP
6.6	NDAs	Yes	Exist at hiring (E04); extend to suppliers	IP
6.7	Remote working	Yes	5 sales mostly remote (E06)	IP
6.8	Event reporting	Yes	2025 near-miss reported informally (E12) — formal channel now	IP
7.1	Physical perimeters	Yes	HQ + leased warehouse (landlord controls, E05)	Impl
7.2	Physical entry	Yes	Server room unlocked (E13) RSK-010	IP
7.3	Securing offices	Yes	Contracts on desks (E13); clear desk in AUP	IP
7.4	Physical monitoring	Yes	Warehouse CCTV by landlord (E05); HQ visitor log new	IP
7.5	Environmental threats	Yes	Standard fire/flood considerations	Impl
7.6	Working in secure areas	Yes	Server room access rules	IP
7.7	Clear desk / clear screen	Yes	E13 findings; AUP §; screen lock GPO	IP
7.8	Equipment siting	Yes	Servers + NAS in one room (E13) — noted single-site risk	Impl
7.9	Off-premises assets	Yes	Sales laptops/mobiles in field RSK-005	IP
7.10	Storage media	Yes	Private USB in production (E03) RSK-014	PI
7.11	Supporting utilities	Yes	UPS unserviced (E13) RSK-008	IP
7.12	Cabling security	Yes	Partially labelled (E13); low priority	PI
7.13	Equipment maintenance	Yes	UPS service contract RSK-008	IP
7.14	Secure disposal	Yes	Disk wiping before disposal — procedure new	PI

8.1	User endpoint devices	Yes	No MDM, BitLocker 50 % (E03) RSK-005	IP
8.2	Privileged access	Yes	MSP shared credential RSK-009; admin separation	IP
8.3	Information access restriction	Yes	ERP over-permissive (E03) RSK-004	PI
8.4	Access to source code	No	No in-house development; e-shop code held by WebFront — governed via 8.30 and	N/A
8.5	Secure authentication	Yes	MFA rollout RSK-001; PayWell without MFA RSK-007	IP
8.6	Capacity management	Yes	ERP servers ageing; monitored by MSP	PI
8.7	Protection against malware	Yes	Defender baseline; anti-phishing policies RSK-001	IP
8.8	Technical vulnerabilities	Yes	No patch schedule (E03); Win7 terminals RSK-014	IP
8.9	Configuration management	Yes	Undocumented infra (E03) RSK-011, RSK-019	PI
8.10	Information deletion	Yes	GDPR retention/erasure duties	PI
8.11	Data masking	No	Test environments use synthetic data per WebFront contract (E10); no other non-prod	N/A
8.12	Data leakage prevention	Yes	Dropbox exfiltration channel RSK-013	PI
8.13	Information backup	Yes	Restore never tested (E03, E07) RSK-002; P SLP-POL-004	IP
8.14	Redundancy	Yes	Single VPN link RSK-006; LTE backup planned	PI
8.15	Logging	Yes	Logs unmonitored (E03) RSK-016	PI
8.16	Monitoring activities	Yes	RSK-016 minimal runbook	PI
8.17	Clock synchronisation	Yes	NTP via domain — verify with MSP	PI
8.18	Privileged utility programs	Yes	RMM tool governance (E07)	PI
8.19	Software installation	Yes	AUP ban on unauthorised software; Win7 exception documented	IP
8.20	Network security	Yes	MSP-managed firewall; flat LAN RSK-002	IP
8.21	Security of network services	Yes	MSP + HostPoint service requirements	PI
8.22	Segregation of networks	Yes	Flat network (E03); segmentation design RSK-002, RSK-014	PI
8.23	Web filtering	Yes	M365/Defender policies — quick win	PI
8.24	Use of cryptography	Yes	BitLocker completion RSK-005; TLS on e-shop	IP
8.25	Secure development lifecycle	Yes	Development outsourced to WebFront; secure development requirements to be implemented	PI
8.26	Application security requirements	Yes	E-shop requirements RSK-003	PI
8.27	Secure architecture	Yes	Applied to segmentation and e-shop changes	PI
8.28	Secure coding	Yes	No in-house development; secure coding to be a contractual obligation for WebFront	PI
8.29	Security testing	Yes	First e-shop pen test RSK-003	PI
8.30	Outsourced development	Yes	WebFront relationship (E10)	IP
8.31	Dev/test/prod separation	Yes	WebFront environments (E10 čl. 6 confirms test env)	Impl

8.32	Change management	Yes	ERP and e-shop changes via MSP/WebFront tickets	PI
8.33	Test information	Yes	Synthetic data per contract (E10)	Impl
8.34	Audit testing protection	Yes	Applies to pen test scoping RSK-003	PI